Risk Register · Scan IA de Cartagenaeste

EU AI Act 2024/1689 · art. 9 · Sistema de gestión de riesgos

Versión 1.0 · 2026-04-23 · Autor: Carlos Galera Román

Revisión: semestral (enero y julio) + tras cada cambio de modelo primario o incidente.

0. Marco de evaluación

Para cada riesgo se valora:

- **Probabilidad (P)**: Alta / Media / Baja.
- **Impacto clínico (I)**: Alto / Medio / Bajo.
- **Riesgo residual (R)**: tras aplicar las mitigaciones = P × I ajustado.

Impacto clínico alto = potencial de perjuicio grave al paciente si el clínico acepta la sugerencia sin revisión (muerte, deterioro irreversible, retraso diagnóstico crítico).

1. Riesgos comunes a todas las modalidades

R-01 · Alucinación del LLM

CAMPO	VALOR
Descripción	El modelo genera información plausible pero incorrecta (dosis, nombres, guías inexistentes).
Probabilidad	**Media** (conocida en todos los LLMs generativos).
Impacto	**Alto** si el clínico copia la respuesta sin validar.
Riesgo residual	**Medio** tras mitigaciones.
Mitigaciones aplicadas	① Supervisión humana art. 14 (checkbox obligatorio). ② Disclaimer permanente EU AI Act. ③ Prompt sistema exige citar guías oficiales. ④ Integración con vademécum propio para validar principio activo. ⑤ Logs `scan_uploads` con `clinicianDecision`.
Owner	Carlos Galera Román
Última revisión	2026-04-23

R-02 · Latencia o caída del proveedor IA durante guardia

CAMPO	VALOR
Descripción	Uno o más proveedores de IA degradados → respuesta tardía o ausente.
Probabilidad	**Media** (ocurre mensualmente en cadenas gratuitas).
Impacto	**Bajo-Medio** (herramienta formativa, no bloqueante).
Riesgo residual	**Bajo**.
Mitigaciones aplicadas	① Cadena de fallback (3-5 proveedores). ② Timeout 25s por proveedor + 3 min total. ③ Cache 7d para prompts repetidos. ④ `healthCheckAi` diario con alerta. ⑤ `/status.html` público.
Owner	Carlos Galera Román
Última revisión	2026-04-23

R-03 · Exposición accidental de datos identificativos del paciente

CAMPO	VALOR
Descripción	El clínico envía una imagen o texto con nombre, NHC, DNI u otros identificadores.
Probabilidad	**Baja-Media** (requiere error humano).
Impacto	**Alto** (violación RGPD, posible sanción AEPD).
Riesgo residual	**Bajo-Medio** tras mitigaciones.
Mitigaciones aplicadas	① Disclaimer RGPD Art. 9 antes del primer envío de imagen. ② `firestore.rules noDni()` bloquea DNI/NIE en campos text. ③ Máximo 4 iniciales en casos. ④ CI `.github/workflows/regex-pii-check.yml` bloquea code commits con PII. ⑤ Prompt IA no almacena prompt ni respuesta literal, solo hash.
Gap	El frontend no valida la imagen (OCR + detección de texto) antes de enviar. → futuro: añadir validación cliente-lado.
Owner	Carlos Galera Román
Última revisión	2026-04-23

R-04 · Cambio silencioso del comportamiento del modelo por el proveedor

CAMPO	VALOR
Descripción	Alibaba/Google/DeepSeek actualiza el modelo sin notificar, cambiando su comportamiento.
Probabilidad	**Media-Alta** (histórico de "drift" conocido).
Impacto	**Medio** (degradación no detectable desde frontend).
Riesgo residual	**Medio**.
Mitigaciones aplicadas	① `modelVersion` se guarda en `scan_uploads` y `aiRequests`. ② `healthCheckAi` detecta caídas de calidad por latencia/errores. ③ Ficha técnica con modelo declarado.
Gap	No hay evaluación continua de calidad del modelo en prod. → futuro: 10 casos gold-standard mensuales evaluados automáticamente.
Owner	Carlos Galera Román
Última revisión	2026-04-23

R-05 · Prompt injection por parte del usuario

CAMPO	VALOR
Descripción	Usuario introduce texto intencionadamente para forzar al modelo a ignorar instrucciones.
Probabilidad	**Baja** (plataforma formativa interna, no abierta al público malicioso).
Impacto	**Bajo** (el output se pega en informe bajo supervisión humana).
Riesgo residual	**Muy bajo**.
Mitigaciones aplicadas	① Prompt sistema con `{system_prompt}\nContexto: {user_context}\nTarea: {task}` separado. ② Validación input en Cloud Function (`validation.ts`). ③ Supervisión humana final.
Owner	Carlos Galera Román
Última revisión	2026-04-23

2. Riesgos específicos · Dermatología

R-D1 · Sesgo de fototipo de piel

CAMPO	VALOR
Descripción	ISIC Archive infrarrepresenta fototipos V-VI → menor sensibilidad en piel oscura.
Probabilidad	**Alta** (documentado en literatura).
Impacto	**Alto** (melanoma no detectado).
Riesgo residual	**Medio-Alto**.
Mitigaciones aplicadas	① Disclaimer en ficha del modelo. ② Prompt exige diferencial ABCDE, no probabilidad única. ③ Recomendación presencial siempre. ④ Registro del caso en `scan_uploads` con decisión clínica.
Gap	Falta indicador explícito "fototipo sospechado" en UI.
Owner	Carlos Galera Román

R-D2 · Confusión de imagen no cutánea

CAMPO	VALOR
Descripción	Modelo puede aplicar categorías ISIC a imágenes de mucosa, uña, etc.
Probabilidad	**Media**.
Impacto	**Bajo** (el clínico sabe el origen de la imagen).
Riesgo residual	**Bajo**.
Mitigaciones aplicadas	① Prompt sistema enumera categorías ISIC válidas. ② Ficha del modelo advierte del dominio.
Owner	Carlos Galera Román

3. Riesgos específicos · Rx tórax

R-T1 · Falso negativo en nódulo pequeño (<8 mm)

CAMPO	VALOR
Descripción	AUROC limitado para nódulos sub-centimétricos; riesgo de falso negativo.
Probabilidad	**Media-Alta** (conocido en CheXNet, CheXpert).
Impacto	**Alto** (retraso diagnóstico de cáncer pulmonar).
Riesgo residual	**Medio**.
Mitigaciones aplicadas	① Prompt sistema incluye Fleischner 2017 (seguimiento TC). ② Recomendación explícita de TC alta resolución si sospecha. ③ Lectura por sistema 12 zonas. ④ Supervisión humana.
Gap	No hay métrica interna propia del recall en nódulos.
Owner	Carlos Galera Román

R-T2 · Error de proyección (AP vs PA)

CAMPO	VALOR
Descripción	AP interpretado como PA sobreestima cardiomegalia.
Probabilidad	**Baja** (fácil de detectar por el clínico).
Impacto	**Bajo-Medio**.
Riesgo residual	**Bajo**.
Mitigaciones aplicadas	① Prompt exige declarar proyección en paso 1. ② Banner de supervisión humana.
Owner	Carlos Galera Román

R-T3 · Artefactos por posición o inspiración

CAMPO	VALOR
Descripción	Rx mal rotada o en espiración puede generar falsos infiltrados.
Probabilidad	**Alta** (frecuente en UCI y urgencias).
Impacto	**Bajo-Medio**.
Riesgo residual	**Bajo**.
Mitigaciones aplicadas	① Prompt paso 1 evalúa calidad técnica antes que hallazgos. ② Disclaimer.
Owner	Carlos Galera Román

4. Riesgos específicos · Rx ósea

R-O1 · Dominio limitado a extremidad superior

CAMPO	VALOR
Descripción	MURA entrenado solo en codo/muñeca/mano. Rendimiento en miembro inferior inexplorado.
Probabilidad	**Alta** si el clínico sube MI sin darse cuenta.
Impacto	**Medio**.
Riesgo residual	**Medio**.
Mitigaciones aplicadas	① Ficha del modelo declara "Rx extremidades superiores". ② Supervisión humana.
Gap	No hay detección automática del tipo de Rx antes del análisis.
Owner	Carlos Galera Román

R-O2 · Edad ósea no legal

CAMPO	VALOR
Descripción	Estimación Greulich-Pyle usada para decisiones forenses o legales.
Probabilidad	**Baja** (no es el uso previsto).
Impacto	**Alto** si se usa en contexto legal.
Riesgo residual	**Bajo**.
Mitigaciones aplicadas	① Disclaimer explícito "orientativo, no legal". ② Posicionamiento formativo.
Owner	Carlos Galera Román

---

5. Riesgos específicos · Rx abdomen

R-A1 · Ausencia de benchmark consolidado

CAMPO	VALOR
Descripción	MONAI enfocado a TC/RM, no Rx simple → no hay métricas de referencia.
Probabilidad	**Alta** (es el estado del arte).
Impacto	**Medio**.
Riesgo residual	**Medio**.
Mitigaciones aplicadas	① Disclaimer explícito en ficha. ② Prompt recomienda TC si sospecha. ③ Rx abdomen se usa casi solo para obstrucción/perforación evidente.
Owner	Carlos Galera Román

---

6. Riesgos específicos · ECG

R-E1 · Foto de papel vs señal digital

CAMPO	VALOR
Descripción	`xresnet1d101` entrenado con WFDB 500Hz digital, no fotos. Artefactos de curvatura, derivaciones perdidas, calibración variable.
Probabilidad	**Alta** (uso habitual en guardia).
Impacto	**Alto** (IAM no detectado por artefacto).
Riesgo residual	**Medio-Alto**.
Mitigaciones aplicadas	① Disclaimer explícito en ficha. ② Integración ECG-GPT (Yale CarDS) como segunda opinión externa. ③ Supervisión humana. ④ Prompt incluye pasos sistemáticos que un humano puede contrastar.
Gap	No hay detector de calidad de imagen (brillo, enfoque, papel doblado).
Owner	Carlos Galera Román

R-E2 · Ritmos poco representados en PTB-XL

CAMPO	VALOR
Descripción	Bloqueos AV avanzados, arritmias poco frecuentes menos representadas.
Probabilidad	**Media**.
Impacto	**Alto** si se omite bradiarritmia con sincopes.
Riesgo residual	**Medio**.
Mitigaciones aplicadas	① Prompt sistema exige explícitamente evaluar PR e intervalos. ② Ficha del modelo menciona superclases PTB-XL. ③ Supervisión humana.
Owner	Carlos Galera Román

---

7. Riesgos específicos · Ecografía

R-EC1 · EchoNet entrenado solo en 4C apical adulto

CAMPO	VALOR
Descripción	Planos alternativos (paraesternal, subcostal) y pediatría fuera de validación.
Probabilidad	**Alta** si se usa con planos distintos.
Impacto	**Medio-Alto**.
Riesgo residual	**Medio**.
Mitigaciones aplicadas	① Prompt sistema exige declarar plano antes del análisis. ② Disclaimer.
Owner	Carlos Galera Román

---

8. Resumen de gaps abiertos

ID	GAP	PRIORIDAD	PLAZO
G-01	Sin validación cliente para detectar PII en imagen antes de enviar	Alta	Q3 2026
G-02	Sin evaluación continua de calidad del modelo en prod (10 casos gold mensuales)	Media	Q3 2026
G-03	Sin indicador "fototipo sospechado" en UI de derma	Baja	Q4 2026
G-04	Sin detector de calidad de imagen para ECG	Media	Q4 2026
G-05	Sin detección automática del tipo de Rx (MI vs MS)	Baja	Q4 2026
G-06	Sin métrica interna propia de recall en nódulos Rx tórax	Baja	2027

Los gaps se revisan en cada revisión semestral de este documento.

9. Relación con otros documentos

- `ehds-readiness.md` · posicionamiento EHDS + plan AI Act.
- `ai-technical-file.md` · ficha técnica art. 11 completa (§4 limitaciones por modalidad).
- `../runbook.md` §9 · respuesta a incidentes SEV-1 (datos expuestos = notificación AEPD 72h).
- `../security-audit-2026-04-21.md` · auditoría de seguridad (riesgos infra).

10. Historial de revisiones

FECHA	VERSIÓN	CAMBIOS
2026-04-23	1.0	Creación del documento con 17 riesgos identificados (5 comunes, 12 específicos). 6 gaps abiertos.